

Azure IAM & Cloud Security Notes

Metadata

- **Topic:** Microsoft Entra Roles, Administrative Units, Custom Domains & Tenant-Wide Settings
- **Date:** 2026-08-26
- **Source Material:** Microsoft Learn — "Implement initial configuration of Microsoft Entra ID"
- **Author/Creator:** Microsoft Learn

Executive Summary (The "So What?")

This module is about the plumbing that everything else in Entra ID sits on top of: who gets to administer the tenant itself, how you carve up that administrative power so no one person has more access than they need, and the tenant-wide settings (branding, domains, default user rights) that shape the whole environment. It matters because over-privileged admin roles — especially casual use of Global Administrator — are one of the biggest real-world risk factors in Entra tenants; understanding Administrative Units and custom roles is what lets you actually practice least privilege instead of just talking about it.

Core Concepts & Architectural Blueprint

- **Key Concept 1:** Microsoft Entra Roles vs. Azure Roles
 - *Definition:* Entra roles manage Entra ID resources (users, groups, domains, licensing) at the tenant level; Azure roles manage Azure resources (VMs, storage, resource groups) at multiple scopes (management group → subscription → resource group → resource). They don't overlap by default.
 - *Security Risk:* A Global Administrator can flip the "Access management for Azure resources" switch to grant themselves the Azure User Access Administrator role across every subscription in the tenant — a powerful, easy-to-overlook privilege escalation path if that switch isn't monitored.
- **Key Concept 2:** Administrative Units (AUs)
 - *Definition:* Containers that scope a role's permissions down to a subset of users, groups, or devices (e.g., only the Research Department) instead of the whole tenant — the Entra ID equivalent of on-prem AD Organizational Units.
 - *Security Risk:* Without AUs, assigning someone the User Administrator role makes them an admin over every single user in the tenant — far more blast radius than most support/helpdesk scenarios actually need.
- **Key Concept 3:** Custom Roles
 - *Definition:* Roles built from scratch by selecting specific granular permissions (e.g., [microsoft.directory/applications/credentials/update](#)) rather than using a broad built-in role. Currently scoped to application registrations and enterprise applications.
 - *Security Risk:* Built-in roles like Application Administrator often grant more than needed (e.g., managing every application in the directory); custom roles let you scope down to just what a specific team actually does.
- **Key Concept 4:** Delegated App Administration
 - *Definition:* Instead of routing all app management through Global Administrator, Entra ID supports app-level delegation: Application Administrator / Cloud Application Administrator roles,

per-app ownership (Enterprise Application Owner, Application Registration Owner), and restricting who can register apps at all.

- *Security Risk:* Leaving "Users can register applications" on the default (Yes) lets any user create app registrations — an easy way for shadow IT or a malicious insider to stand up an unmonitored app with its own permissions.
- **Key Concept 5:** Custom Domains & the ForceDelete Trap
 - *Definition:* Only a Global Administrator can add/remove custom domains. A domain can't be deleted while any user, group, or app still references it — ForceDelete exists to bulk-rename those references back to the default *.onmicrosoft.com domain.
 - *Security Risk:* Running ForceDelete carelessly silently renames UPNs/email addresses/app URIs across the tenant — a bulk identity change that could break sign-in or federation if done without checking what depends on that domain first.
- **Key Concept 6:** Tenant-Wide User Settings & Security Defaults
 - *Definition:* Settings that apply globally — whether users can register apps, whether non-admins can access the Entra admin portal, guest user permission levels, and Security Defaults (free, preconfigured baseline: forces MFA registration, blocks legacy auth, requires admin MFA).
 - *Security Risk:* Guest users get materially fewer default permissions than member users (can't enumerate the full directory), which is by design — loosening those defaults without a reason widens the tenant's exposure to external accounts.

Common Cloud Misconfigurations & Attack Vectors

- **The Flaw:** Overuse of the Global Administrator role for routine tasks
 - **Exploit Mechanism:** Global Admin has unrestricted access to every administrative feature in the tenant — if that account is phished, the attacker gets everything at once, including the ability to grant themselves Azure resource access via the elevation switch.
 - **Remediation:** Microsoft explicitly recommends against relying on Global Administrator day-to-day — use scoped built-in roles (User Administrator, Application Administrator, etc.) or custom roles instead, and require MFA on all privileged roles.
- **The Flaw:** No Administrative Units, so every delegated admin has tenant-wide reach
 - **Exploit Mechanism:** A helpdesk admin meant to support one regional office can reset passwords or manage users for the entire organization — a compromised or careless account has far more reach than the job actually requires.
 - **Remediation:** Scope admin roles to Administrative Units matching real organizational boundaries (region, department) rather than assigning tenant-wide roles by default.
- **The Flaw:** Leaving "Users can register applications" enabled tenant-wide
 - **Exploit Mechanism:** Any authenticated user can register a new app registration and, by default, becomes its owner — a route for shadow IT, or for an attacker with any valid account to create a foothold application with its own credentials and permissions.
 - **Remediation:** Set app registration to No in User Settings, and grant it back selectively via the Application Developer role only to people who need it.

Simulated Lab / Proof of Concept

1. **Objective:** Assign and remove an Entra role for a user, and create a custom role scoped to application credential management.
2. **Steps Taken:**

- Step 1: Created a new user (Adele Vance) in the Microsoft Entra admin center under Identity → Users → All Users.
 - Step 2: Opened the user's profile → Assigned roles → Add assignments → assigned Application Administrator.
 - Step 3: Verified the role appeared on the user's Assigned roles page, then removed it the same way (Assigned roles → select role → Remove) to test the reverse path.
 - Step 4: Under Roles and administrators → New custom role, created a role scoped to just two permissions: [microsoft.directory/applications/credentials/update](#) and [microsoft.directory/applications/basic/update](#) — deliberately narrower than the built-in Application Administrator role.
3. **Verification:** Confirmed the custom role appeared in the list of assignable roles after creation, and that removing a role assignment immediately drops it from the user's Assigned roles list with no residual access.
 4. **Outcome:** Demonstrated the difference between a broad built-in role (Application Administrator — manages all apps, SSO settings, Proxy config) and a purpose-built custom role scoped to only credential/basic-property updates — the kind of scoping that supports real least-privilege delegation instead of defaulting to the nearest built-in role.

Key Vocabulary

- **Microsoft Entra Role:** A role controlling permissions over Entra ID resources (users, groups, domains, licenses) — distinct from Azure roles.
- **Administrative Unit (AU):** A container scoping a role's reach to a subset of users/groups/devices — the cloud analog of on-prem AD Organizational Units.
- **Custom Role:** A role built from individually selected granular permissions rather than a built-in bundle; currently limited to app registration/enterprise app permissions.
- **Global Administrator:** The most powerful built-in Entra role — full control over the tenant; Microsoft explicitly discourages routine use.
- **Application Administrator / Cloud Application Administrator:** Delegated roles for managing all apps in the directory, minus Conditional Access (and minus Application Proxy for the Cloud variant).
- **Enterprise Application Owner / Application Registration Owner:** Per-app delegation roles scoped to only the apps a person owns, not the whole directory.
- **ForceDelete:** An operation that bulk-renames all references to a custom domain back to the default [*.onmicrosoft.com](#) domain so it can be deleted.
- **Security Defaults:** A free, preconfigured baseline security policy (MFA registration required, legacy auth blocked, admin MFA enforced) available to every Entra tenant.
- **Tenant Properties:** Directory-wide settings — name, country/region, tenant ID, technical contact, privacy statement URL.
- **Member User vs. Guest User:** Two default permission tiers — member users get full directory read and self-service rights; guest users (B2B) get materially restricted visibility into the directory.